



ESCUELA SUPERIOR
DE GUERRA

"General Rafael Reyes Prieto"

Colombia

Legal y Regulatorio - SOC.



MY. GOMEZ GUZMAN
VICTOR



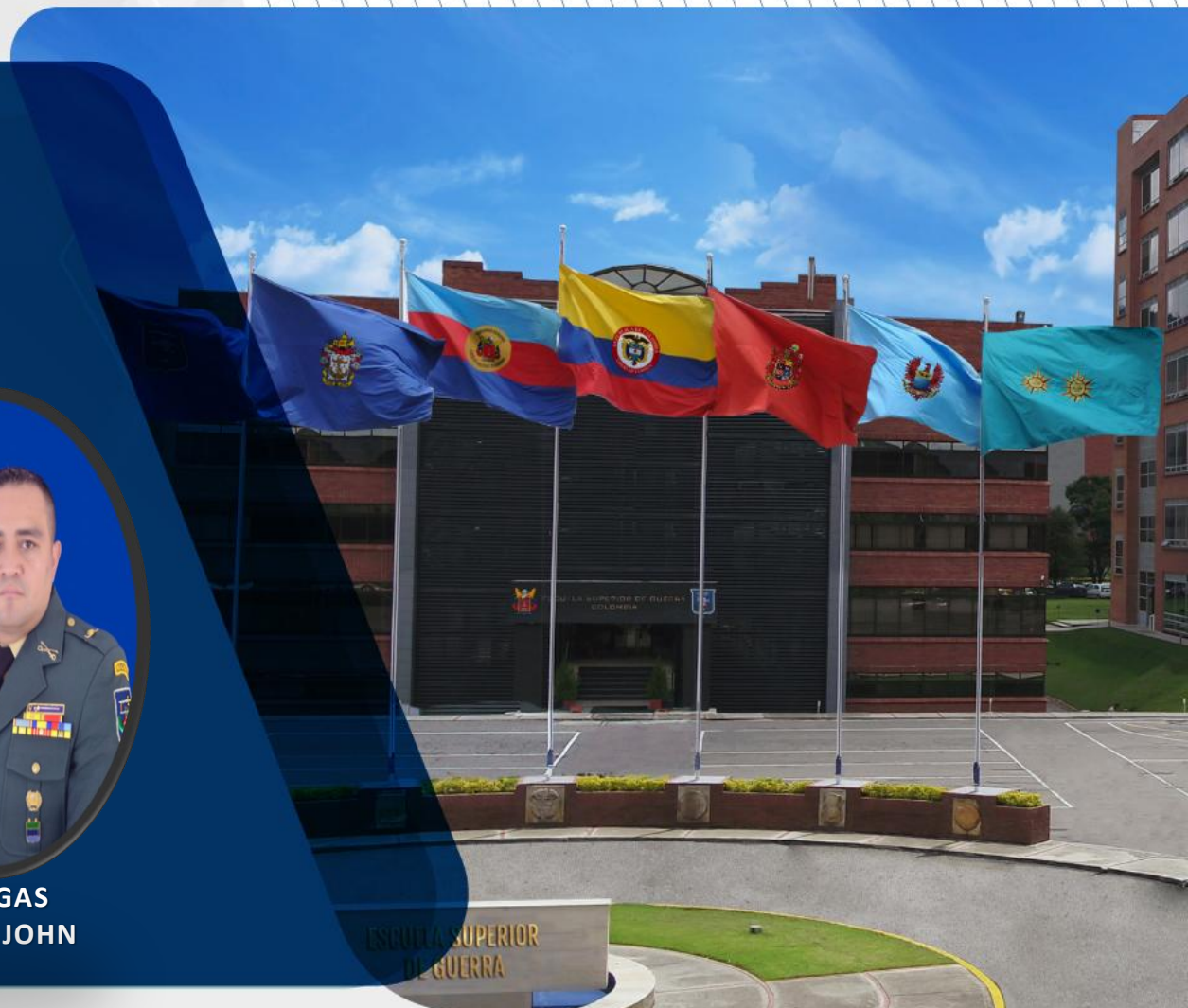
MY. GARNICA TORRES
MIGUEL



MY. RINCON SOLANO
RUBEN



MY. VARGAS
MARTINEZ JOHN





- 01 Introducción.
- 02 Legal y Regulatorio. (Cumplimiento)
- 03 Privacidad.
- 04 Auditoría.
- 05 Investigaciones.
- 06 Protección de la Propiedad Intelectual - Revisión del contrato.
- 07 SOC “**Centro de Operaciones de Seguridad**”.
- 08 Conclusiones.

AGENDA



Introducción

CISO MIND MAP



En un mundo digital lleno de amenazas y regulaciones, el **CISO (Chief Information Security Officer)** tiene la tarea de **proteger la información** y garantizar que las empresas cumplan con las normativas. Donde se analizarán los **principales estándares de seguridad, leyes de privacidad y auditorías** que deben seguirse para evitar sanciones y riesgos legales. Desde proteger datos financieros y médicos hasta garantizar la seguridad en bancos y empresas tecnológicas, el cumplimiento normativo es clave para operar con confianza en el mundo digital.

Cumplimiento

PCI: (Payment Card Industry Data Security Standard)

Es un estándar de seguridad contractual impuesto por las principales marcas de tarjetas de pago, Obliga a bancos, tiendas y empresas que procesan pagos a proteger los datos de clientes.

HIPAA: (Health Insurance Portability and Accountability Act)

Regulación en EE.UU. para proteger datos médicos y de salud, Obliga a hospitales, clínicas y aseguradoras a proteger la información de pacientes.

FERPA: (Family Educational Rights and Privacy Act)

Protege la privacidad de los registros educativos de estudiantes en EE.UU, Impide que escuelas y universidades compartan datos sin el consentimiento de los estudiantes o sus padres.

NIST SP 800-37 y 800-53

Estándares de seguridad para agencias gubernamentales en EE.UU.

NIST 800-37 define cómo evaluar y gestionar riesgos de seguridad.

NIST 800-53 establece controles de seguridad para proteger la información.

1



2



3



4



5



6



7



SOX: (Sarbanes-Oxley Act)

Ley de EE.UU. para la seguridad de la información financiera de empresas públicas. Exige controles estrictos para evitar fraudes financieros y manipulación de datos.

FFIEC: (Federal Financial Institutions Examination Council) & CAT (Cybersecurity Assessment Tool)

Regulaciones para bancos y entidades financieras en EE.UU, Obligan a las instituciones financieras a tener controles de seguridad contra fraudes y ciberataques.

NERC CIP: (North American Electric Reliability Corporation - Critical Infrastructure Protection)

Regulación de seguridad para la infraestructura eléctrica en EE.UU, Obliga a compañías eléctricas a proteger sus sistemas contra ciberataques.



Privacidad



Las **leyes de privacidad protegen** los datos personales y establecen cómo deben ser recopilados, almacenados y compartidos.



Privacy Shield

Acuerdo entre EE.UU. y la UE para la transferencia de datos personales, regula cómo las empresas de EE.UU. manejan los datos de ciudadanos europeos.



EU GDPR: (General Data Protection Regulation).

Ley de protección de datos de **la Unión Europea obliga a las empresas** a:

- Obtener consentimiento antes de recopilar información.
- Informar a los usuarios sobre el uso de sus datos.
- Permitir que los usuarios eliminen sus datos ("Derecho al olvido").

Las auditorías verifican que las empresas cumplan con las regulaciones y que sus sistemas sean seguros.

1

SSAE 16 (Statement on Standards for Attestation Engagements 16) .

- Estándar de auditoría para evaluar controles de seguridad y operativos en empresas.

2

SOC 2 (Service Organization Control 2) .

- Informe de auditoría que demuestra que una empresa maneja datos de clientes con altos estándares de seguridad.

3

ISO 27001.

- Certificación internacional para la gestión de seguridad de la información.

Auditoría



4

NIST SP 800-53A

Guía para evaluar la efectividad de los controles de seguridad en agencias gubernamentales.

5

FISMA (Federal Information Security Management Act) & FedRAMP (Federal Risk and Authorization Management Program) .

- Regulaciones de seguridad para agencias del gobierno de EE.UU. y proveedores de tecnología.

6

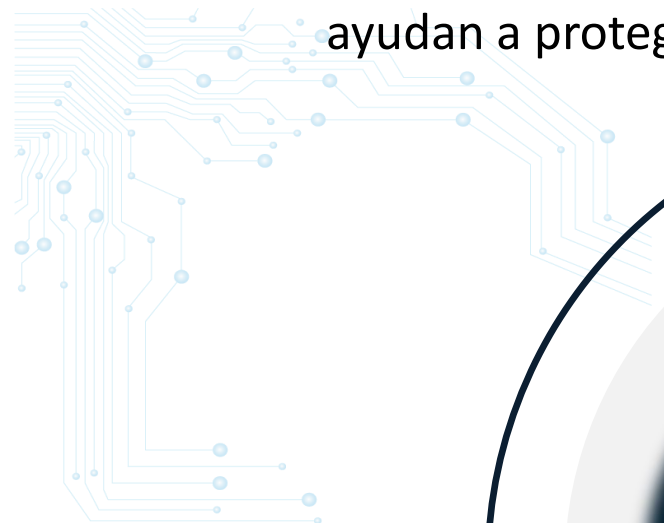
COSO (Committee of Sponsoring Organizations of the Treadway Commission)

Marco de control interno usado para auditorías financieras y de seguridad.

Versión 2025

**UNIÓN, PROYECCIÓN,
LIDERAZGO**

Las **investigaciones forenses** y la protección de la propiedad intelectual ayudan a proteger información y responder a delitos digitales.



1

2

3

eDiscovery

Búsqueda y recuperación de datos digitales para investigaciones legales.

FORENSE DIGITAL

Análisis de dispositivos y registros digitales después de un ciberataque.



5. Protección de la Propiedad Intelectual: (IP Protection)

Prevención del robo de patentes, marcas y secretos industriales.

6. Revisión del contrato:

Asegurar que acuerdos comerciales cumplan con regulaciones de seguridad.

7. Requisitos del cliente:

Empresas que manejan datos de clientes deben cumplir con sus exigencias de seguridad.

8. Riesgo de demanda:

Reducción del riesgo legal ante fugas de datos.





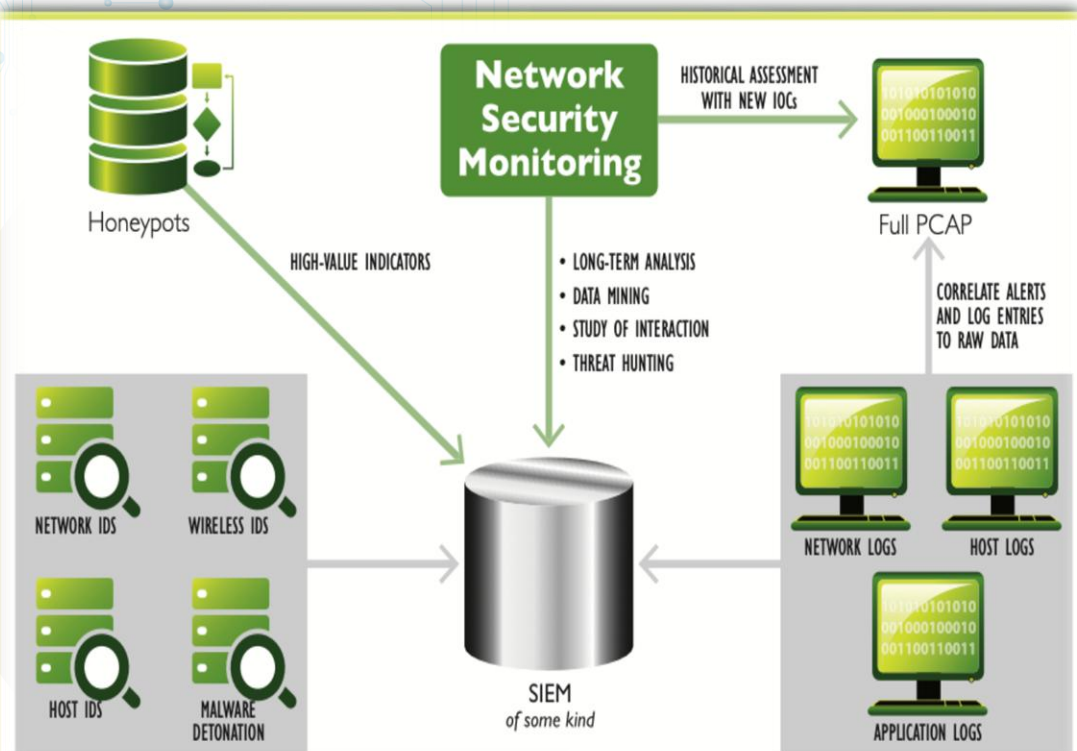
SOC

**Funciones Esenciales del
Centro de Operaciones de
Seguridad.**

UNIÓN, PROYECCIÓN, LIDERAZGO

Centro de Operaciones de Seguridad

Esquema de Monitoreo de Seguridad en Redes herramientas para detectar, analizar y mitigar amenazas cibernéticas



Elementos Claves

Honeypots (Sistemas trampa): servidores que atraen atacantes y recopilan información sobre sus tácticas técnicas y procedimientos.

IDS – Intrusion Detection Systems (Sistemas de detección de intrusos): Herramienta que permite monitorear, detectar, analizar e identificar.

SIEM (Security Information and Event Management): recibe y analiza información para detectar amenazas.

Full PCAP (Captura completa de paquetes): evalúa y analiza y permite correlacionar alertas de seguridad para identificar ataques avanzados.

Logs (Registros de Seguridad): herramientas que nos permite identificar tráfico de red, seguridad de dispositivos y registro de actividades.

PROCESO DE MONITOREO

- Recolección datos
- Analiza y correlaciona en el SIEM
- Evalúa y detecta amenazas
- Respuesta y mitigación



Honeypots (Trampas de seguridad)

- Sistemas diseñados para atraer a atacantes y recopilar información sobre sus técnicas y herramientas.
- Generan **indicadores de compromiso (IoCs, por sus siglas en inglés)** valiosos para mejorar la seguridad.

Network Security Monitoring

(Monitoreo de Seguridad en la Red) Ley de protección de datos de la Unión Europea.

- Proceso continuo implica la supervisión de la red para detectar actividades sospechosas.
- Informar a los usuarios sobre el uso de sus datos.

Análisis a largo plazo: revisión de patrones de tráfico y eventos con el tiempo.

Minería de datos: extracción de información útil de grandes volúmenes de datos.

Estudio de la interacción: análisis de cómo se comunican los sistemas y los atacantes.

Caza de amenazas (Threat Hunting): búsqueda proactiva de amenazas ocultas en la red.



Centro de Operaciones de Seguridad



SIEM (Sistema de Gestión de Información y Eventos de Seguridad)

- (Security Information and Event Management) recopila, analiza y correlaciona eventos de diferentes fuentes de seguridad.
- Generan indicadores de compromiso (IoCs, por sus siglas en inglés) valiosos para mejorar la seguridad..
- **Análisis a largo plazo:** Revisión de patrones de tráfico y eventos con el tiempo.
- **Minería de datos:** Extracción de información útil de grandes volúmenes de datos.
- **Estudio de la interacción:** Análisis de cómo se comunican los sistemas y los atacantes.
- **Caza de amenazas (Threat Hunting):** Búsqueda proactiva de amenazas ocultas en la red.



IDS (Sistemas de Detección de Intrusos)

- Network IDS (NIDS): Monitorea el tráfico de red en busca de amenazas.
- Wireless IDS (WIDS): Analiza las redes inalámbricas en busca de ataques como la suplantación de puntos de acceso.
- Host IDS (HIDS): Supervisa actividades en un equipo específico para detectar anomalías.
- Malware Detonation (Detonación de Malware): Se refiere a entornos controlados donde se ejecuta malware para analizar su comportamiento.





Centro de Operaciones de Seguridad



Full PCAP (Captura Completa de Paquetes)

- Recolección de todos los paquetes de datos transmitidos en la red para un análisis detallado.



Logs y Análisis de Datos

- Network Logs (Registros de Red):
Guardan información sobre el tráfico de la red, ayudando a detectar ataques.
- Host Logs (Registros del Host):
Contienen eventos relacionados con sistemas individuales.
- Application Logs (Registros de Aplicaciones):
Monitorean el comportamiento de las aplicaciones para detectar anomalías.



Arkime

Full Packet Capture

Evaluación Histórica con Nuevos IoCs

- Indicadores de Compromiso (IoCs) se actualizan constantemente.
- Se revisan registros históricos para identificar si la red ya fue comprometida por ataques previos no detectados en su momento.

Conclusión.



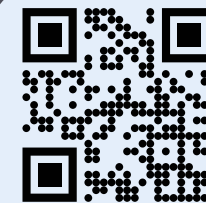
Cumplimiento Normativo

- Protege a las empresas de sanciones y refuerza su reputación. La privacidad de los datos es clave, con regulaciones como **GDPR y HIPAA**. Las auditorías aseguran estándares de seguridad, mientras que la forensia digital permite responder eficazmente a incidentes.
- El **CISO** debe gestionar riesgos de forma proactiva, adaptándose a un entorno de amenazas en constante evolución.
- **SOC** Monitorear, Prevenir, Detectar, Investigar y responder a las amenazas cibernéticas las **24 horas del día**.



Preguntas

AUDITORIO
BICENTENARIO BATALLA DE AYACUCHO
UNIÓN - INTEGRIDAD - VICTORIA



@EsdegCol



Escuela Superior
de Guerra



Escuela Superior
de Guerra



Escuela Superior
de Guerra

www.esdegue.edu.co



ESCUELA SUPERIOR
DE GUERRA
"General Rafael Reyes Prieto"
Colombia

ISO 9001:2015
ISO 21001:2018

BUREAU VERITAS
Certification



La ***Escuela Superior de Guerra "General Rafael Reyes Prieto"*** está
certificada bajo las normas internacionales **ISO 9001:2015** e **ISO**
21001:2018.



Gracias



AUDITORIO
BICENTENARIO BATALLA DE AYACUCHO
UNIÓN - INTEGRIDAD - VICTORIA



@EsdegCol



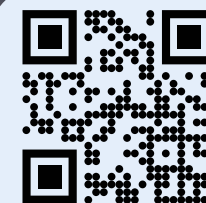
Escuela Superior
de Guerra



Escuela Superior
de Guerra



Escuela Superior
de Guerra



www.esdegue.edu.co